GRANITE SMS · SCHOOL MANAGEMENT SYSTEM

Audit and handover

13 November 2026 · covers the whole system: server, web app, database, deployment and the Mwangaza Academy demo

Granite SMS was audited end to end to decide whether a real Kenyan school could run on it. Every problem found has been fixed, the missing features a school needs have been built, and each screen has been checked in a browser on a laptop and a phone. Two items stay open by choice, and a short list of settings must be made before the first school goes live.

All
critical, high, medium and low findings fixed

180
automated tests, run on every change

9
new features built (fees ledger, SMS, M-Pesa, parents…)

2
items left open by choice

1. What the audit found, and what was done

The findings were graded by harm to a school: **critical** loses money or marks or lets one user take over another; **high** is a security hole or a wrong result a school would notice; **medium** and **low** cost time or trust.

Area	What was wrong	Status
Money	Two payments at the same moment could both be applied; reversals had no approval; overpayments were refused; receipt numbers could skip or repeat.	Fixed
Backups	Restore could wipe a live school; there was no tested off-site copy.	Fixed*
Accounts and sign-in	Weak session rules, no lockout or rate limits, and a timing leak at login.	Fixed
Exams and results	Published results could change afterwards; grading didn't follow CBE; any teacher could claim an unassigned marksheet.	Fixed
Data integrity	Missing database links let records point at nothing.	Fixed
Speed	Big lists loaded everything at once (8.8 MB, 4.6 s); now a page at a time (18 KB, under 0.15 s).	Fixed
School calendar	No current term or time zone, so screens opened on the wrong term and dates were in UTC.	Fixed
Learners and parents	Learners saw staff screens and zeros; parents had no way in.	Fixed
Tests and checks	Almost no automated tests; nothing ran on each change.	Fixed

* The nightly off-site backup is built and verified but stays switched off until its storage keys are added (see section 4).

2. What was built

For the office

- **Fees ledger**: payments spread across invoices, credit carried forward, bursaries, statements with a running balance.
- **M-Pesa**: paybill payments land on the right learner by admission number; the bursar places the rest by hand.
- **Payments register**: every receipt by day, week, month or term, totals by method, any receipt reprinted.
- **SMS to parents** (Africa's Talking): receipts, absences, results and notices.
- **Guardians, promotion, leavers, Excel import and data export.**

For teachers, learners and parents

- **CBE grading** with rubric levels, KCSE points and a scale per class.
- **Term report cards** combining exams by weight, with comments.
- **One-page PDF** result slips and report cards, on the school's own design (layout, colour, motto, wording, which parts show).
- **Parent portal** (phone sign-in), learner home, noticeboard.
- **Privacy tools**: consent, anonymising leavers, retention.

Screens

Every screen was checked for every role at laptop and phone width, with no errors and no sideways scrolling. Long lists are paged and grouped (exams by term, attendance by week, notices by month); there is a search box on every page (Ctrl K), a fixed sidebar, breadcrumbs and consistent loading placeholders.

3. Left open, on purpose

Item	Why it waits	Status
Timetable, discipline, library, transport, staff records	New modules, not fixes. Worth doing one at a time once a school is using the system; the timetable is the most asked for.	Open
Prisma 7 upgrade	It changes how every database call is made. Nothing is broken on the current version (6.19); do it as its own change with the full test suite.	Open
Error tracking (Sentry)	Ready to switch on; needs an account and its key.	Needs a key

4. Before the first school goes live

Hosting (Render)

- [ ] Rotate the passwords that were exposed earlier.
- [ ] Set `JWT_EXPIRES_IN` (7d suggested).
- [ ] Set the health check to `/health/ready`.
- [ ] For SMS: `SMS_PROVIDER` and the `AT_*` keys.
- [ ] For M-Pesa: `MPESA_ENC_KEY`, `PUBLIC_API_URL` and the Daraja keys.
- [ ] Add the backup storage keys to switch on nightly off-site backups.

Data

- [ ] Before deploying: run `npm run db:orphans` and `npm run fees:reconcile` (read-only) on the live database.
- [ ] After deploying: run `npm run results:freeze -- --write` once.

In the app, per school

- [ ] Settings: term dates and the current term.
- [ ] Settings: upload the logo again (PNG or JPEG prints best).
- [ ] Settings → Branding: choose the report card design.
- [ ] Turn on SMS and choose which messages go out.
- [ ] Link M-Pesa paybill and press "Connect paybill".

Paperwork (each school)

- [ ] Register with the ODPC as a data controller.
- [ ] Sign a data-processing agreement with the school.
- [ ] Publish a privacy notice for parents.

Demo

- [ ] Run "Refresh demo" in GitHub Actions after these changes.

> **Where the detail lives.** `AUDIT_REPORT.md` lists every finding with its fix and commit; `docs/` covers backups, SMS, M-Pesa and privacy; `DEMO.md` covers the demo.